

Cyber Protection Policy Application: Cedar Ridge Accounting Group (Sample)

Application form

Harborline Insurance Company · Cyber Protection Policy Application · Form HIC-CY-APP (10/26)

SPECIMEN: completed sample for illustration only. Harborline Insurance Company and all people named below are fictional.

Before you start

- **This application becomes part of your policy** if we issue one. We rely on your answers to decide whether to insure you, on what terms and at what price.
- **Answer honestly, and say so if you're unsure.** Honest mistakes lead to adjusted terms, not a void policy (policy Section V, part 3). Only deliberate, material misstatements can void coverage.
- **We only hold you to the questions we ask.** You don't need to volunteer anything else. Answers marked "optional" are for our information only.
- **Ask your IT provider to help.** Many security questions are best answered with them. Where we ask for evidence, attach a screenshot or export.
- **We scan your internet-facing systems before we issue a policy.** We won't later use anything that scan showed to deny a claim. The one exception: a known-exploited vulnerability we warned you about in writing that stayed unfixed for 45 days (policy Section III, part 1.7).
- **Liability coverages are claims-made and reported,** and defense costs reduce your limits.

Most businesses finish in about 20 minutes. Checked boxes (☑) show this sample applicant's answers.

Part 1: Applicant and business information

#	Question	Answer
1.1	Legal name of applicant	Cedar Ridge Accounting Group, LLC
1.2	Trade name (if different)	Cedar Ridge CPAs
1.3	Main address	1450 Market Street, Suite 600, Denver, CO 80202
1.4	Other locations	Boulder, CO (satellite office, 9 staff)
1.5	Website and email domains	cedarridgecpa.com
1.6	Entity type and year founded	Limited liability company, 2009
1.7	Industry and NAICS code	Accounting services, NAICS 541211 (Offices of Certified Public Accountants)
1.8	Describe what you do	Tax preparation, audit and review, bookkeeping and outsourced payroll for about 2,400 individual and 380 business clients
1.9	Revenue: last fiscal year / next 12 months	\$8,100,000 / \$8,500,000 (projected)
1.10	Does any one customer provide more than 10% of revenue?	☐ Yes ☒ No. Largest client is about 3%
1.11	Employees	62 (54 full-time, 8 seasonal during tax season)
1.12	Subsidiaries or affiliates to be covered	None
1.13	As a business, do you offer adult content, cannabis, cryptocurrency, gambling, debt collection, managed IT services for others, or payment processing for others (processing card or bank payments for other businesses)? Running payroll for your own clients is asked in 5.4	☐ Yes ☒ No
1.14	Main contact	Dana Whitfield, Managing Partner (dana.whitfield@cedarridgecpa.com)
1.15	Security contact (receives our security alerts)	Marcus Oyelaran, IT and Security Manager (marcus.oyelaran@cedarridgecpa.com)

Part 2: Coverage requested and insurance history

#	Question	Answer
2.1	Proposed effective date	October 15, 2026
2.2	Aggregate limit requested	☐ \$1,000,000 ☒ \$2,000,000 ☐ \$3,000,000
2.3	Retention	☒ Standard for our revenue band (\$10,000 before credits) ☐ Higher retention for a lower premium
2.4	Optional coverages requested	☒ P. Dependent system failure ☐ Q. Website tracking liability ☒ R. Increased fraud limit (\$500,000) ☐ S. Key customer interruption ☐ T. Impersonation response ☐ System failure full-limit option

#	Question	Answer
2.5	Do you have cyber insurance now?	☒ Yes ☐ No. A \$50,000 cyber sublimit inside our business owners policy, expiring October 15, 2026
2.6	Why are you buying standalone coverage?	Our current sublimit would not cover a ransomware attack or a breach of client tax records; two business clients now require at least \$1M of cyber coverage
2.7	Has any insurer declined, cancelled or refused to renew cyber coverage for you in the last 3 years?	☐ Yes ☒ No
2.8	Retroactive date requested	Full prior acts
2.9	Do you carry professional liability (accountants' errors and omissions) insurance?	☒ Yes ☐ No. \$2,000,000 limit, claims-made, renewing June 1, 2027

Part 3: Data and privacy

#	Question	Answer
3.1	Which types of personal information do you store?	☒ Social Security numbers ☒ Financial account numbers ☒ Tax returns ☒ Driver's license numbers ☒ Limited health information (medical deductions, HSA records) ☐ Payment card numbers (we don't store them; see 3.10) ☐ Biometric data
3.2	Approximate number of individuals whose personal information you hold	About 31,000 current and former clients, dependents and employees (7-year retention), including about 1,300 employees of our 40 payroll clients. Most records include a Social Security number
3.3	Where do those individuals live?	Colorado about 88%; the rest across 26 other states
3.4	Do you keep paper records with personal information?	☒ Yes ☐ No. Scanned and shredded since 2020; older files in locked offsite storage
3.5a	Are laptops encrypted?	☒ Yes ☐ No. Full-disk encryption on all laptops
3.5b	How do you send documents containing personal information?	Through our encrypted client portal. A data-loss rule blocks Social Security numbers in outgoing email
3.5c	Is cloud storage encrypted?	☒ Yes ☐ No
3.6	Do you have a written retention and deletion schedule?	☒ Yes ☐ No. Records kept 7 years under our schedule (longer than the IRS minimum periods), then securely deleted
3.7	Does your website have a privacy policy?	☒ Yes ☐ No. Last reviewed March 2026
3.8	Which tracking tools run on your website or apps?	Google Analytics 4 only, behind a cookie consent banner. ☐ Meta or ad pixels ☐ Session replay ☐ Chat widgets
3.9	Do you sell or share personal information for advertising?	☐ Yes ☒ No
3.10	Do you accept payment cards? If yes, how?	☒ Yes ☐ No. Client fees through our processor's hosted payment page; about \$410,000 a year; card numbers never touch our systems (PCI self-assessment SAQ A)

Part 4: Security controls

Questions follow the six functions of the NIST Cybersecurity Framework 2.0 and the CIS Controls v8.1 essential safeguards. Answers marked ★ decide your security credits.

Govern

#	Question	Answer
4.1	Is one named person responsible for information security?	☒ Yes ☐ No. IT and Security Manager, reporting to the managing partner
4.2	Do you have a written information security program?	☒ Yes ☐ No. Required for us under the FTC Safeguards Rule; last reviewed March 2026
4.3	Do you use an outside IT provider?	☒ Yes ☐ No. Front Range IT Partners (managed IT provider) handles patching and helpdesk under a written contract

Identify

#	Question	Answer
4.4	Do you keep an up-to-date inventory of devices and software?	☒ Yes ☐ No. Automated through endpoint management: 71 laptops, 14 phones, 2 on-site servers
4.5	Have you completed a security risk assessment in the last 12 months?	☒ Yes ☐ No. January 2026, by our IT provider
4.6	Do you run any operating system or software past the end of vendor support?	☒ Yes ☐ No. One legacy print server (Windows Server 2012 R2), isolated on its own network segment; replacement scheduled for December 2026. All laptops run Windows 11

Protect

#	Question	Answer
4.7 ★	Is multi-factor authentication (MFA) required for:	☒ Email (all users) ☒ Remote access and VPN ☒ Cloud and admin accounts ☒ Tax, accounting and payroll platforms
4.8	List any accounts without MFA	One scanner service account, limited to our internal network and unable to log in remotely. Evidence: Microsoft 365 conditional access report attached. (For information: admin accounts use hardware security keys.)
4.9 ★	How do staff connect remotely?	Company VPN with MFA, on current supported firmware. ☐ Remote desktop (RDP) open to the internet ☐ End-of-life VPN or remote tools. Our old VPN appliance was replaced in 2025
4.10	How does your IT provider connect to your systems?	Through its remote monitoring and management tool, with MFA, access limited to named technicians, and every session logged
4.11	Are admin accounts separate from everyday accounts?	☒ Yes ☐ No. Three admin accounts; staff have no local admin rights
4.12	How quickly are critical patches applied?	Internet-facing systems within 72 hours; everything else within 14 days. Our IT provider tracks CISA's Known Exploited Vulnerabilities catalog

#	Question	Answer
4.13	Email protections	☒ SPF ☒ DKIM ☒ DMARC set to reject ☒ Advanced filtering ☒ External-sender warning banner
4.14	Security awareness training	☒ Yes ☐ No. Annual training plus quarterly phishing tests; 96% completion in 2026
4.15 ★	Is endpoint detection and response (EDR) installed on all laptops and servers?	☒ Yes ☐ No. Installed on 100% of laptops and servers. Evidence: EDR console export attached
4.16	Are your IRS e-Services and e-file credentials protected with MFA and limited to named staff?	☒ Yes ☐ No. Four named staff; reviewed each January

Detect

#	Question	Answer
4.17 ★	Are EDR alerts watched 24/7 by a managed detection and response service that can isolate devices?	☐ Yes ☒ No. Our IT provider reviews alerts 8 a.m. to 6 p.m. Mountain time on business days
4.18	How long do you keep security logs?	Microsoft 365 audit logs kept 180 days, with alerts sent to our IT provider

Respond

#	Question	Answer
4.19	Do you have a written incident response plan?	☒ Yes ☐ No. Updated February 2026; includes breach counsel contacts and state notice deadlines
4.20	Has the plan been tested?	☒ Yes ☐ No. Ransomware tabletop exercise, April 2026

Recover

#	Question	Answer
4.21 ★	How are critical systems and data backed up?	Daily cloud backups of Microsoft 365 and our file server, with an immutable copy, plus a weekly offline copy
4.22	Are backups protected from your own admin accounts?	☒ Yes ☐ No. The backup console uses separate admin accounts with MFA, and the immutable copy can't be deleted by our own admins
4.23 ★	When did you last successfully test a full restore?	June 12, 2026. File server restored in 6 hours. Evidence: restore-test log attached
4.24	How long could you operate without your main systems?	About 1 day during tax season (February–April); about 3 days otherwise

Part 5: Fraud and payment controls

#	Question	Answer
5.1	Who can send wires or ACH payments from your own accounts?	Two partners and the controller; any payment over \$10,000 needs two approvals. About 60 outgoing payments a month, typically under \$25,000
5.2 ★	Before adding or changing bank or payment details for a vendor, client, employee or a payroll client's employee, do you confirm by phone using a number from your own records?	☒ Yes ☐ No. Written procedure; numbers come from our own records, never from the request. Evidence: procedure and 2026 training records attached
5.3 ★	Do you confirm the same way for any transfer over \$5,000 requested by email, text, messaging app, phone or video call?	☒ Yes ☐ No
5.4	Do you move money on behalf of clients?	☒ Yes ☐ No. Payroll for 40 business clients through our payroll platform, with dual approval on every batch
5.5	If yes: how much client money do you move, and what is the largest single transfer or batch?	About \$2.4 million a month across 40 clients; largest single payroll batch about \$210,000
5.6	Do you use positive pay or similar bank fraud controls?	☒ Yes ☐ No
5.7	Are staff trained to spot fake invoices, business email compromise and deepfake calls?	☒ Yes ☐ No. Training includes a code-word check for any urgent payment request by voice or video
5.8	How do you send invoices?	Mostly through our secure client portal; some by emailed PDF

Part 6: Vendors, AI and technology use

#	Question	Answer
6.1	Which outside providers would stop your business if they went down?	Microsoft 365 (email and files); our cloud tax-preparation platform; our payroll platform; our managed IT provider; our client portal
6.2	How did you agree to their terms?	Written contracts with our IT provider and payroll platform; standard online terms for the others
6.3	Do you review key vendors' security?	☒ Yes ☐ No. We obtain SOC 2 reports from our IT provider and payroll platform each year
6.4	Do you use artificial intelligence tools?	☒ Yes ☐ No. Microsoft 365 Copilot for drafting and summarizing
6.5	Do you have rules for using AI?	☒ Yes ☐ No. A written policy bans entering client Social Security numbers or tax data into public AI tools
6.6	Can any AI tool you use send payments, emails or files on its own, without a person approving each step?	☐ Yes ☒ No. Copilot drafts and summarizes only; a person sends everything
6.7	Do you develop or sell software?	☐ Yes ☒ No

Part 7: Regulatory footprint

#	Question	Answer
7.1	Do you prepare tax returns, run payroll or provide other financial services for individuals?	☒ Yes ☐ No. Tax preparation and payroll. Our written information security plan follows IRS Publication 4557 and the FTC Safeguards Rule
7.2	Do you receive patient information from healthcare providers or health plans (HIPAA)?	☐ Yes ☒ No. The health information in 3.1 comes from individual tax clients about themselves
7.3	Are you an SEC reporting company, or regulated by the New York Department of Financial Services?	☐ Yes ☒ No
7.4	Which PCI DSS self-assessment questionnaire does your card processor require?	SAQ A
7.5	In the last calendar year, did you process the personal data of 100,000 or more Colorado consumers (not counting employees or business contacts)? Do you earn revenue or discounts from selling personal data?	☐ Yes ☒ No / ☐ Yes ☒ No. About 27,000 Colorado individuals in total, including employees; we don't sell data
7.6	Do you collect biometric data (fingerprints, face or voice scans)?	☐ Yes ☒ No

Part 8: Loss history and known circumstances

#	Question	Answer
8.1	In the last 3 years, have you had any of the following: a data breach (unauthorized access to personal information that required, or might have required, notice to anyone); a ransomware attack or extortion demand; a loss of money to a fraudulent payment request; or a cyber-related claim or lawsuit?	☐ Yes ☒ No
8.2	Optional: describe any attacks you stopped. (Optional answers are for our information only and can't be used to deny a claim)	February 2025: an email posing as a vendor asked us to change its bank details. Our callback procedure caught it; no money was sent. March 2026: a phishing email captured one employee's password; MFA blocked the login, and we reset the account the same day
8.3	Has any regulator asked you about privacy or data security?	☐ Yes ☒ No
8.4	Does any partner, officer or your IT and security manager know of any fact or situation that could reasonably lead to a claim under this policy?	☐ Yes ☒ No

Part 9: Signatures and fraud warnings

Our statement

We have answered these questions after reasonable inquiry, including with our IT provider. We will tell Harborline if any answer changes before the effective date. We understand that an honest mistake leads to adjusted terms rather than a void policy, but that a deliberate, material misstatement can void coverage.

Signed	Name and title	Date
/s/ Dana Whitfield	Dana Whitfield, Managing Partner	September 24, 2026
/s/ Marcus Oyelaran	Marcus Oyelaran, IT and Security Manager	September 24, 2026

We agree to receive policy documents and notices electronically.

Fraud warnings

All applicants: Anyone who knowingly gives false or misleading information to obtain insurance, or to be paid on a claim, may be committing a crime and may face fines, imprisonment and denial of benefits.

Colorado applicants: It is unlawful to knowingly provide false, incomplete, or misleading facts or information to an insurance company for the purpose of defrauding or attempting to defraud the company. Penalties may include imprisonment, fines, denial of insurance, and civil damages. Any insurance company or agent of an insurance company who knowingly provides false, incomplete, or misleading facts or information to a policyholder or claimant for the purpose of defrauding or attempting to defraud the policyholder or claimant with regard to a settlement or award payable from insurance proceeds shall be reported to the Colorado Division of Insurance within the Department of Regulatory Agencies.

Other states' required warnings are included on the state-specific version of this form.

Evidence attached

1. Microsoft 365 conditional access report (MFA, 4.7–4.8)
2. EDR console export showing coverage of all laptops and servers (4.15)
3. Restore-test log, June 12, 2026 (4.23)
4. Written payment verification procedure and 2026 training records (5.2–5.3)

For underwriter use: how these answers set the policy terms

Every ★ answer, and each answer below, maps to a specific term on the Declarations issued to Cedar Ridge (policy HIC-CY-2026-004817).

Answer	Result on the Declarations
Revenue \$8.5M (1.9)	Standard retention \$10,000 (revenue band \$5M–\$25M)
MFA on all listed systems and EDR on all devices (4.7, 4.15)	25% retention credit: retention \$7,500
No 24/7 managed detection and response (4.17)	Retention not cut 50%; waiting period for attacks stays at 8 hours
MFA on all remote access, no end-of-life VPN (4.9)	10% premium credit: –\$853
Restore tested June 2026, immutable and offline copies (4.21, 4.23)	No ransomware coinsurance. To keep the credit, retest by June 12, 2027
Written verification procedure, with training (5.2, 5.3)	Coverage H at its full limit
Client payroll of \$2.4M a month, largest batch \$210,000 (5.4, 5.5)	Coverage R recommended and purchased: fraud limit \$500,000, so one diverted batch plus recovery costs fits within the limit
About 31,000 records, mostly with Social Security numbers, and a tax-season peak (3.2, 4.24)	\$2,000,000 limit, under our limit rule: \$1M base; \$2M for more than about 25,000 sensitive records, client money or a seasonal peak; \$3M where a contract requires it
Tax and payroll platforms would stop the business; 1-day tolerance in tax season (6.1, 4.24)	Coverage P recommended and purchased: \$250,000, 24-hour waiting period
No customer above 10% of revenue (1.10)	Coverage S not needed
Google Analytics only, with consent banner (3.8)	Coverage Q offered but not required
Accountants' professional liability in force (2.9)	Coordination under policy Section V, part 9.2
Scanner service account without MFA, disclosed (4.8)	Accepted. Because it was disclosed, it cannot later be used to deny a claim
Legacy print server past end of support, isolated (4.6); pre-issue scan, September 20, 2026: no critical findings, one medium finding (outdated encryption settings on the same server)	Recorded. Fix requested within 30 days. A medium finding does not affect the claim-free reduction, which depends only on critical issues
Mid-term changes	Cedar Ridge must tell us within 30 days if it stops using a verified control in Item 7

Premium build: core coverages at the \$1M base limit \$6,120, plus the increase to \$2M \$1,530, plus Coverage P \$600, plus Coverage R \$280, equals \$8,530. Less the 10% security credit (\$853): **\$7,677**.